

Course code: GRC1100

Course name: Governance, Risk, and Compliance

Assessment type: Individual home exam

Date of examination/hand out- and hand in date: 07.11.2025

Permitted exam materials and equipment: All aids allowed

File format: Pdf

Number of pages: 4

Plagiarism detection:

All exam papers, including bachelor's and master's theses, will be checked for plagiarism. You can read more about this in the guidelines on citing sources (referencing), plagiarism, and formal requirements for submitting assignments.

All submissions must include a Declaration on the Use of AI Tools.

Guidelines for the Assignment:

- It is not permitted to reuse the case description from your project.
- The Declaration on the Use of AI Tools and Resources form (last page of the assignment description) must be completed and placed before the assignment answers in the report. *(This page is not counted as part of the 15-page limit.)*
- Each task has a specific page limit. The total submission must not exceed 15 pages of content. This means cover page + table of contents + AI declaration + 15 pages of content + reference list.
- Use Arial or Calibri, 11–12 pt, with 1.5 line spacing.
- Use tables and visualizations actively in your answers.
- Always include explanatory text with tables and images to provide context.
- Provide references to support assumptions or choices made in your answer. The most important thing is that references are used correctly and appropriately. The preferred citation style is either IEEE / Vancouver or APA.

General information:

- Start uploading your exam paper/file ahead of time, as it may take a long time to upload
- Exam papers that are not handed in on Wiseflow by the specified time of the submission date will not be proceeded to assessment
- Before submitting, remember to check that all files can be opened and that every file is included. It may be a good idea to check the saved files on several machines before submitting them in Wiseflow.
- Incorrect file format or lacking documents may result in the submission not being passed or assessed.
- The total file size of the entire exam paper/file must not exceed 5GB in zip format or 5MB in PDF format

Evaluation criteria:

Task #	Title	Point/ 100
T1	Case Analysis and Digital Business Modeling (max 3 pages)	15
T2	Risk assessment (max 5 pages)	25
T3	GDPR Compliance Mapping (max 3 pages)	20
T4	Security Awareness Program (max 4 pages)	15
	Overall quality, use of frameworks/ tools/ standards, and presentation	25
Total		100

Task 1: Case Analysis and Digital Business Modeling (max 3 pages)

Description:

Describe a fictional private company within an industry of your choice. The company should be significantly digitalized, have less than 100 employees, and offer specific core products or services. The company must be unique to your submission (not reused from your project).

Tasks:

1. **Case description:** Provide a brief overview of the company, including its name, business idea, target group, core products/services, and vision.
2. **Digital enablement:** Explain how the company's digital solutions, systems, or data flows support its core business processes and value creation.
3. **Information security relevance:** Discuss what confidentiality, integrity, and availability mean for the company's core operations and deliveries.
4. **Visualization:**
 - Create and describe a visualization of one core process **or** data flow within the company.
 - The visualization can take the form of a business process model (e.g., BPMN, flowchart) or a system-oriented model (e.g., data flow diagram, context diagram, or system architecture sketch)—choose the toolset that best supports your analytical approach.
 - Explain briefly how information and communication technology (ICT) supports or enables this process or flow supporting value creation.

Task 2: Risk assessment (max 5 pages)

Description:

Building on the company and your chosen visualization from Task 1, conduct a threat and risk analysis for that same core process or digital system. The analysis should identify what could compromise its security and how the company can reduce those risks.

Tasks:

1. **System context:**
 - Briefly restate the process or system from Task 1, focusing on its key **information assets** and how they are used or stored.
2. **Threats and vulnerabilities:**
 - Identify up to **10 threats** to these assets and assess them
 - For each, describe possible **vulnerabilities** that the threat can exploit.
3. **Risk analysis:**
 - Define the risk and assess the potential impact on Confidentiality, Integrity, and Availability (CIA) if each threat were realized, using a scale of your choice.
 - Consider possible business, legal, and reputational consequences.
 - Combine likelihood and impact in a risk matrix, or another suitable tool, to prioritize the most significant risks.
 - Propose appropriate controls (technical, organizational, or administrative) to reduce prioritized risks, and briefly explain how each control mitigates the related threat or vulnerability.) for the most significant risks, explaining how each mitigates a threat or vulnerability.

4. Control recommendation:

- Summarize your findings with three to five key recommendations for company leadership.
- These should focus on strategic and managerial actions (e.g., policy updates, staff training, investment priorities, and governance improvements) that will strengthen the company's overall security posture.

Task 3: GDPR Compliance Mapping (max 3 pages)

Description:

Based on the company you described in **Task 1**, analyze how the General Data Protection Regulation (GDPR) applies to its operations. Assume that the company processes some form of personal data—such as customer information, employee records, or user analytics—through its digital systems or services.

Tasks:

1. **Identify and summarize** 6–10 GDPR articles that are most relevant to your company's data-processing activities.
2. **Explain the relevance** of each article in the context of your company's business model, products/services, and data handling practices.
3. **Describe compliance measures:** For each article, outline what the company must do to meet its obligations. Include brief, practical examples related to your case (e.g., data minimization in customer onboarding, lawful basis for analytics, access controls for HR data).

Task 4: Security Awareness Program (max 4 pages)

Description:

Your company's management has decided to invest in a security awareness program to help employees understand risks, act responsibly, and contribute to protecting the company. The program should be based on the company's own risks and needs. Use the results from your case description, risk and GDPR analysis as a starting point.

Tasks:

1. **Human risks:**
 - Identify up to three key human actions or missing routines that pose the greatest security risks to the company.
 2. **Program planning:**
 - Define the target group(s) (e.g., all employees, management, technical staff).
 - Choose topics to include (e.g., phishing, passwords, data sharing, physical security) based on your risk analysis.
 - Decide how to deliver the training or awareness (e.g., courses, email campaigns, intranet posts, workshops, games).
 - Specify how often activities should take place and how to measure their effectiveness.
 3. **Behavioral change:**
 - Design your campaign and suggest creative ideas to motivate employees and encourage secure behavior.
 - Provide examples of messages, stories, slogans, campaigns, or visuals that could be used to promote security awareness and mitigate your chosen risks.
-

Copy this into your submission and fill it out.

Declaration of the Use of AI Tools and Resources

The checklist below must be completed:

- **Text correction:** Have parts of the text been checked using tools such as Grammarly, Ginger, LanguageTool, or similar? Yes / No
- **Text generation:** Have parts of the text been generated using tools such as ChatGPT, Jasper, WriteSonic, or similar? Yes / No
- **Writing assistance:** Have any ideas or approaches in the report been suggested by tools such as ChatGPT, Google Bard, or similar? Yes / No
- **Image generation:** Have any images/figures in the report been generated using tools such as Midjourney, DALL·E, or similar? Yes / No
- **Other AI tools:** Have you used any other AI tools? If yes, please specify here:

Have you used any AI-based tools or resources in the preparation of this report?

If yes, specify the tool and its purpose below.

1. **Text generation** – If you used text-based tools, which tasks were completed with AI assistance, and how?
2. **Images, tables and figures** – If you used image/figure generators, which images or diagrams were AI-generated?

I declare that all use of AI tools or resources has been clearly disclosed either in the report or in this declaration form.

Candidate number / Date
